ETH
Eidgenössische Technische Hochschule Zürich
Swiss Federal Institute of Technology Zurich

Semester Project Proposal

Automated and Agile Threat Modeling for Security in Industrial Control System

Student: Mehdi Berrada
Supervisor: Hoang Nguyen
Professor: Prof. David Basin

1 Prerequisites

Familiarity with threat modeling (i.e., attack tree and data-flow diagram). [1]

2 Motivation

Industrial Control Systems (ICS), are essential infrastructures in various sectors, ranging from energy to healthcare. [4] These systems, inherently complex and hybrid in nature, have evolved to incorporate both cloud and on-device functionalities. This evolution, while beneficial, has also rendered ICS highly susceptible to cyber threats, with the potential for significant security breaches. The complexity and continual evolution of ICS systems pose substantial challenges in maintaining their security.

Traditionally, threat modeling in ICS has been a manual and time-intensive process, lacking the agility to adapt to the rapidly changing threat landscape. In response to these challenges, there has been a paradigm shift in security engineering towards a *shift-left* approach. This approach emphasizes integrating security aspects early in the system development process. A key component of this strategy is the concept of *threat modeling as code*, which leverages the Open Threat Model (OTM) [1] format to streamline and automate threat modeling. More specifically, the OTM format is a tool-agnostic specification that uses YAML or JSON to represent threat models in a code-based format. It details system components, trust boundaries and dataflows. This format facilitates the understanding and automation of threat modeling, making it adaptable for various tools in assessing and addressing security vulnerabilities in a system.

The primary objective of this project is to refine the threat modeling process for ICS. By leveraging automation and the principles of *shift-left* security, this project aims to address the complexities and evolving nature of ICS, enhancing their resilience against cyber threats while complying with the increasingly stringent requirements set by regulatory bodies.

[1] E.g., see the course on Security Engineering: `https://www.vorlesungen.ethz.ch/Vorlesungsverzeichnis/lerneinheit.view?lerneinheitId=172154&semkez=2023W`

3 Objective

The primary goal is to create a tool that bridges the gap between traditional and modern threat modeling practices, offering a robust, agile solution for the complex and evolving world of ICS security.

The project aims to define an automated system that combines the Open Threat Model (OTM) format with open-source tools like Threagile [2] and pytm [3], specifically tailored for ICS. A key objective is to design *threat modeling as code* to enhance efficiency and agility. While focusing on automation, the system will also be capable of generating standard modeling artifacts such as data flow diagrams and attack trees, ensuring compliance with regulatory requirements and aiding in comprehensive security analysis.

4 Tasks

1. Investigate the Open Threat Model (OTM) and the specific tools such as Threagile [2], and pytm [3]: functionalities and intercompatibility.
2. Implement a custom library for Threagile or pytm to effectively model threats for on-premise ICS components like PLCs.
3. Design an extension for cloud-based components in ICS, ensuring compatibility with cloud services like AWS (or GCP, Azure) in the threat modeling tools.
4. Investigate how to incorporate this automated threat modeling into CI/CD pipelines for ongoing security assessment.

5 Deliverables

The following deliverables are due at the end of the project:

Final report The final report should consist of an introduction; a theoretical background section; one or more sections describing the modeling, implementation and evaluation (if any); and a conclusion. The report may be written in English or German.

Source code Complete development including easily reproducible evaluation.

Presentation At the end of the project, a 20 minute presentation must be given in an InfSec group seminar. It should give an overview and discuss the most important highlights of the work.

References

References

[1] Open Threat Model (OTM). `https://iriusrisk.github.io/startleft/`.

[2] Threagile - Agile Threat Modeling. `https://github.com/threagile`, 2023.

[3] pytm - A Pythonic Framework for Threat Modeling. `https://github.com/izar/pytm`, 2024.

[4] NIST: National Institute of Standards and Technology. Managing Information Security Risk: Organization, Mission, and Information System View. `https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-39.pdf`, 2011.